GUÍA DE PREPARACIÓN PARA LA DEFENSA ORAL — ACTIVIDAD 4

Correo Institucional Seguro: Postfix, Dovecot IMAPS, Tríada Criptográfica (SPF/DKIM/DMARC) y Antispam

Asignatura: Tecnología Web I (SIS-0150)

Institución: Universidad Privada Domingo Savio (UPDS), Sede Santa Cruz de la Sierra

Docente Evaluador: M.Sc. Ing. Jimmy Nataniel Requena Llorentty

Equipo Estudiantil: Ketfer Gianella Salazar, Charles Yourdan Conde, Brian Calás, Marco Barriga, Adaniel Balderrama

Fecha: 25 de Octubre de 2026

Pregunta 1: ¿Cuál es la diferencia fundamental entre el puerto 25 y el puerto 587 en la arquitectura SMTP?

- **Respuesta Técnica:**

Aunque ambos puertos ejecutan el protocolo SMTP (RFC 5321), tienen roles y políticas de seguridad completamente opuestos:

- **Puerto 25 (SMTP Relay inter-servidor):** Es el canal utilizado exclusivamente para la transferencia de mensajes entre Agentes de Transferencia de Correo (**MTA a MTA**, ej. de `mail.horizonte.internal` a `mail.familia.internal`). Tradicionalmente no exige autenticación de usuario porque cualquier servidor de Internet debe poder entregar correo al destinatario local, pero aplica restricciones estrictas contra relé abierto (`reject_unauth_destination`) y usa cifrado oportunista STARTTLS.
- **Puerto 587 (Submission - RFC 6409):** Es el canal de **inyección de mensajes desde los clientes hacia el servidor (MUA a MSA)**. En este puerto, la política es de confianza cero: **la autenticación SASL (usuario y contraseña) y el cifrado TLS son 100% obligatorios** antes de aceptar cualquier comando `MAIL FROM`. En nuestro laboratorio, Postfix está configurado con `smtpd_tls_auth_only = yes`, lo que impide que un cliente siquiera vea o use mecanismos de autenticación si no ha establecido primero una sesión TLS 1.3.

Pregunta 2: ¿Por qué es una vulnerabilidad crítica mantener abierto el puerto IMAP 143 y cómo se garantizó su clausura en Dovecot?

- **Respuesta Técnica:**

El puerto IMAP 143 estándar transmite los comandos del protocolo y las credenciales en **texto claro (ASCII no cifrado)**. Si un usuario se conecta desde una red local, Wi-Fi institucional o punto de acceso compartido, un atacante pasivo ejecutando un sniffer como Wireshark o `tcpdump` puede capturar fácilmente los paquetes TCP y extraer el usuario y contraseña del comando `LOGIN <usuario> <password>`, comprometiendo el buzón completo.

Aunque el puerto 143 admite la actualización STARTTLS, los atacantes pueden ejecutar ataques de degradación (*STARTTLS Stripping*), interceptando el banner y eliminando la capacidad TLS para forzar la autenticación en claro.

Solución implementada: En `/etc/dovecot/conf.d/99-horizonte.conf` se desactivó por completo el listener en claro mediante:

```
service imap-login {
  inet_listener imap {
    port = 0
  }
}
```

De esta forma, el daemon Dovecot ni siquiera abre el puerto 143 (`Connection refused`), forzando de manera estricta y matemática el uso de **IMAPS en el puerto 993 con TLS implícito desde el byte 0 de la conexión**.

Pregunta 3: ¿Qué significan cada uno de los parámetros de la cabecera `DKIM-Signature` y qué sucede si un atacante altera un solo carácter del cuerpo?

- **Respuesta Técnica:**

La cabecera DKIM (RFC 6376) contiene la firma criptográfica que garantiza autenticidad de origen e integridad de contenido:

- `v=1`: Versión del estándar DKIM.
- `a=rsa-sha256`: Algoritmo de firma digital asimétrica (RSA con función hash criptográfica SHA-256).
- `c=relaxed/simple`: Algoritmo de canonización. `relaxed` para cabeceras (ignora diferencias menores de espacios en blanco) y `simple` para el cuerpo (no tolera modificaciones).
- `d=horizonte.internal`: Dominio firmante que asume la responsabilidad del mensaje.
- `s=mail`: Selector de clave DNS. Indica al receptor que debe buscar la clave pública en `mail._domainkey.horizonte.internal`.
- `bh=f0AAIg3b...`: **Body Hash**. Es el resumen criptográfico SHA-256 codificado en Base64 calculado sobre el cuerpo del mensaje.
- `b=x4VW1TLf...`: **Firma Digital**. Es el hash de las cabeceras críticas (`Date`, `To`, `From`, `Subject`) y del propio `bh=`, cifrado con la clave privada RSA de 2048 bits de Postfix.

Impacto ante alteraciones: Si un atacante en tránsito altera una sola letra, número o espacio en el cuerpo del correo, el servidor de destino recalcula el hash SHA-256 del cuerpo y obtiene un valor divergente de `bh=`. Esto hace que la verificación de la firma digital falle de inmediato (`dkim=fail`), activando la política DMARC de rechazo o cuarentena.

Pregunta 4: ¿Por qué un registro SPF con terminación `~all` o `?all` es insuficiente y por qué configuramos `-all`?

- **Respuesta Técnica:**

El calificador final del registro SPF (RFC 7208) determina qué acción debe tomar el servidor receptor si la IP del remitente no coincide con los servidores autorizados:

- `+all`: Acepta todo (permisivo total, anula la seguridad).
- `?all` (*Neutral*): El dominio no declara si la IP está autorizada o no. Los filtros antispam no pueden tomar una decisión determinante y no bloquean la suplantación.
- `~all` (*SoftFail*): El correo no autorizado se marca como sospechoso pero usualmente se entrega en la bandeja de entrada o en spam. Muchos atacantes aprovechan dominios con SoftFail para enviar campañas de phishing con alta tasa de éxito.
- `-all` (*HardFail - Rechazo Estricto*): Indica explícitamente a los servidores receptores de todo el mundo que **ninguna otra IP que no sea la listada en el registro MX tiene autorización para emitir correo**. Si un atacante intenta enviar un correo usando nuestro dominio desde otra IP, el receptor rechaza la conexión en el acto con código SMTP 550.

En nuestro DNS BIND 9 publicamos: `v=spf1 mx -all`, garantizando la máxima protección de reputación.

Pregunta 5: ¿Qué es la "alineación de dominio" en DMARC y por qué es indispensable contra el phishing?

- **Respuesta Técnica:**

SPF y DKIM por sí solos tienen un fallo de diseño que los spammers aprovechan:

- SPF valida la IP contra el dominio del **Envelope Sender** (`MAIL FROM` en la sesión SMTP, invisible para el usuario).
- DKIM valida que el mensaje esté firmado por el dominio presente en la etiqueta `d=` de la cabecera DKIM.

Un atacante puede registrar un dominio propio (ej. `atacante.com`), publicar SPF y DKIM válidos para su dominio, pero colocar en el encabezado visible del cliente de correo `From: director@horizonte.internal`. Para el usuario, el correo parece 100% auténtico del director, y SPF/DKIM darían "Pass" porque validaron `atacante.com`.

DMARC (RFC 7489) resuelve esto mediante la Alineación:

Exige que el dominio visible en la cabecera `From:` coincida exactamente con el dominio validado por SPF y/o el dominio validado por DKIM (`d=`). En nuestro servidor configuramos alineación estricta (`adkim=s; aspf=s`), lo que significa que no se permiten ni siquiera subdominios: si el remitente dice `@horizonte.internal`, la firma DKIM y el SPF deben pertenecer estrictamente a `horizonte.internal`. Si no alinean, DMARC aplica la política `p=quarantine`.

Pregunta 6: ¿Cómo previene Postfix que un usuario autenticado envíe correos usando la dirección de otra persona (*Anti-Spoofing*)?

- **Respuesta Técnica:**

En una configuración básica de Postfix con SASL, un usuario que se autentica exitosamente como `secretaria` podría ejecutar el comando `MAIL FROM: <director@horizonte.internal>` y el servidor lo enviaría sin rechistar.

Para blindar el sistema contra la suplantación interna, implementamos dos directivas en `/etc/postfix/master.cf` bajo el servicio `submission`:

1. `-o smtpd_sender_restrictions=reject_sender_login_mismatch`: Obliga a Postfix a cruzar la identidad del usuario SASL autenticado con la dirección remitente especificada en `MAIL FROM`.
2. `-o smtpd_sender_login_maps=pcre:/etc/postfix/remitentes.pcre`: Define la tabla de correspondencia legítima.

Si la usuaria `secretaria` intenta emitir como `rosario.vaca@horizonte.internal`, Postfix intercepta la solicitud y devuelve el código de error:

`553 5.7.1 Sender address rejected: not owned by user secretaria`.

Pregunta 7: ¿Por qué un correo legítimo puede ser catalogado como spam si carece de resolución inversa (PTR / FCrDNS)?

- **Respuesta Técnica:**

Los grandes proveedores de correo (Google, Microsoft, Yahoo) implementan la verificación **FCrDNS* (Forward-Confirmed Reverse DNS)*:

1. Cuando un servidor de correo conecta a la IP de destino, el receptor consulta el DNS inverso (registro PTR) de la IP conectada.
2. Luego toma el nombre de host devuelto (ej. `mail.horizonte.internal`) y realiza una consulta DNS directa (registro A) para comprobar si ese nombre resuelve exactamente a la misma IP de origen.
3. Finalmente, compara este nombre con el banner que el servidor emite en el comando `HELO/EHLO`.

Si la IP emisora no tiene registro PTR o si pertenece a un rango de IP dinámico/residencial, los filtros antispam asumen inmediatamente que se trata de una máquina zombie o botnet infectada enviando correo masivo, asignando una penalización severa o descartando la conexión antes del envío del cuerpo.

Pregunta 8: ¿Cómo colaboran Postfix, Rspamd y ClamAV mediante el protocolo Milter?

- **Respuesta Técnica:**

- Postfix se comunica con **Rspamd** mediante el protocolo **Milter* (Mail Filter)* en el puerto TCP `inet:localhost:11332`. Durante la sesión SMTP (en tiempo real), Postfix pausa la transacción y transmite los metadatos y el contenido del correo a Rspamd.
- Rspamd ejecuta múltiples módulos concurrentes:
- Valida SPF, DKIM y DMARC.
- Consulta listas negras en tiempo real (DNSBL/RBL).
- Aplica análisis bayesiano estadístico de lenguaje.
- Extrae archivos adjuntos y los envía al daemon **ClamAV** a través de su socket UNIX `/var/run/clamav/clamd.ctl`.

- **Toma de decisiones:**

- Si ClamAV detecta un virus o macro maliciosa, o si el score acumulado es ≥ 11.0, Rspamd instruye a Postfix a rechazar el correo en plena sesión con código `554 5.7.1`.
- Si el puntaje es intermedio (6.0 a 11.0), agrega la cabecera `X-Spam: Yes` para que Dovecot Sieve lo mueva a la carpeta *Junk*.
- Si el puntaje es menor a 6.0, el correo se entrega limpio en la bandeja de entrada.

Pregunta 9: ¿Cómo se ejecuta una migración técnica sin pérdida de datos desde cuentas de Gmail personales hacia el nuevo servidor institucional?

- **Respuesta Técnica:**

El procedimiento técnico se basa en la herramienta de sincronización bidireccional **`imapsync`**:

1. **Aprovisionamiento previo:** Se crean los buzones en Dovecot (`nombres.apellidos@horizonte.internal`) con su estructura Maildir correspondiente.
2. **Extracción y Sincronización:** Se ejecuta `imapsync` conectando simultáneamente al servidor origen (Gmail IMAP vía SSL puerto 993 con App Password) y al servidor local Dovecot (puerto 993 con certificado institucional). `imapsync` copia todas las carpetas, banderas (leído/no leído) y archivos adjuntos preservando los timestamps originales (`RFC 2822`).
3. **Sincronización diferencial:** Durante la fase de convivencia de 30 días, se programa una tarea cron que ejecuta `imapsync` cada medianoche para transferir únicamente los correos nuevos que hayan seguido llegando a la cuenta vieja.
4. **Respuesta automática:** Se configura un auto-responder en Gmail informando a los contactos externos el cambio de domicilio postal electrónico oficial.
5. **Cierre:** Al día 46, se desconecta el reenvío y la organización opera exclusivamente bajo la infraestructura propia con copias de respaldo automatizadas en Restic.